摘要：

攻击者利用以太坊新特性EIP-7702，诱导币安热钱包签下50条授权，在约3分24秒内扫空167,464枚ETH及63种代币。链上数据指向签名系统遭到渗透，而非私钥直接被盗。Tether、Circle、Arbitrum安全委员会等多方迅速冻结资产，但约33亿美元BTC和ETH仍在链上追踪中。

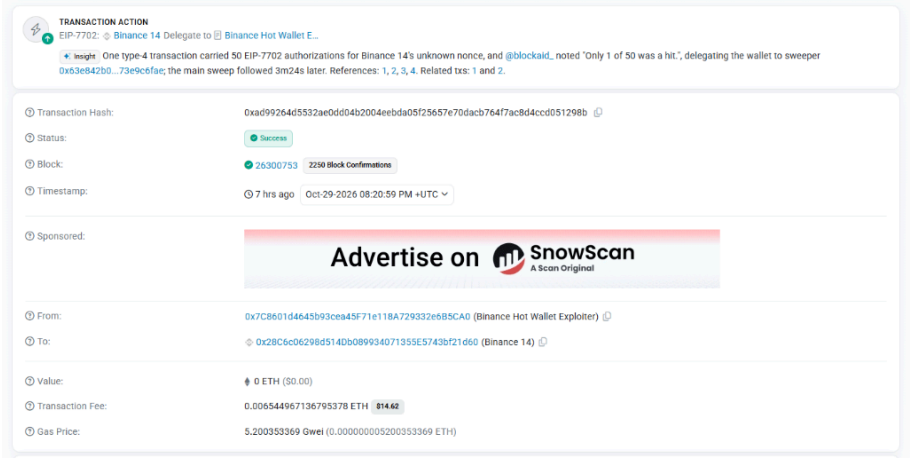
10月30日凌晨，币安疑似遭遇“黑客攻击”，旗下多个钱包出现大额资金转出，消息迅速刷屏币圈。币安称正在调查安全事件，创始人赵长鹏（CZ）说：“看起来像是针对币安的黑客攻击。”

币安最新回应称，**估计总影响金额约63亿美元**（官方用的是“估计”和“总影响金额”而不是实际损失），已与合作方冻结约30亿美元，损失由SAFU基金及公司自有资金承担。充值和提现暂停，恢复时间未公布。



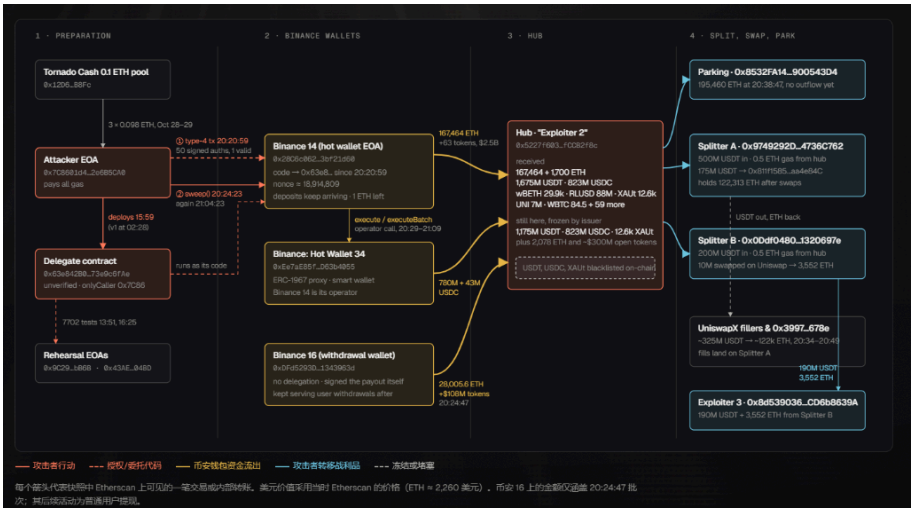
据链上数据分析，北京时间10月30日凌晨4点20分59秒，一笔以太坊交易完成上链。它没有转账金额，也没有调用数据，唯一的内容，是向币安标记为"Binance 14"的热钱包提交了50条EIP-7702授权。

3分24秒后，这个钱包里的167464枚ETH、16.15亿枚USDT，以及UNI、LINK、AAVE、PEPE等63种代币，在一笔交易里被全部转走。



同一时段，其他链上的币安钱包也有资金转出。按DRK整理的链上时间线，换算成北京时间，Base链在4点16分、比特币在4点20分、Tron在4点22分，已有资金转出。808bits则记录，XRP账本上约4点05分至4点09分，五个币安钱包已向同一账户转出2.335亿枚XRP。

DRK统计，**约63亿美元资产在约40分钟内，从八条链上的币安钱包流出，以太坊是最大的一段。比特币方面，18,270枚BTC在同一个区块内转出，约合14亿美元。**



至于怎么发生的，币安的初步调查指向一名DevOps工程师的笔记本电脑被入侵：攻击者借此访问服务容器，提交了未经授权的提现交易。币安称，尚未发现私钥泄露的证据。攻击者是谁，目前没有机构公开认定。币安承诺调查完成后公布完整的事后调查报告。

消息传出后，比特币一度跌至6周低点77,646美元，BNB 24小时内下跌超过8%。

黑客提前布置，演练两次，与一份提前48小时准备的“委托书”

Cobo联合创始人、链上分析人士神鱼在事件发生数小时后发布了链上复盘视频，顺着链上痕迹倒推，攻击准备至少在事发前两天就已启动。

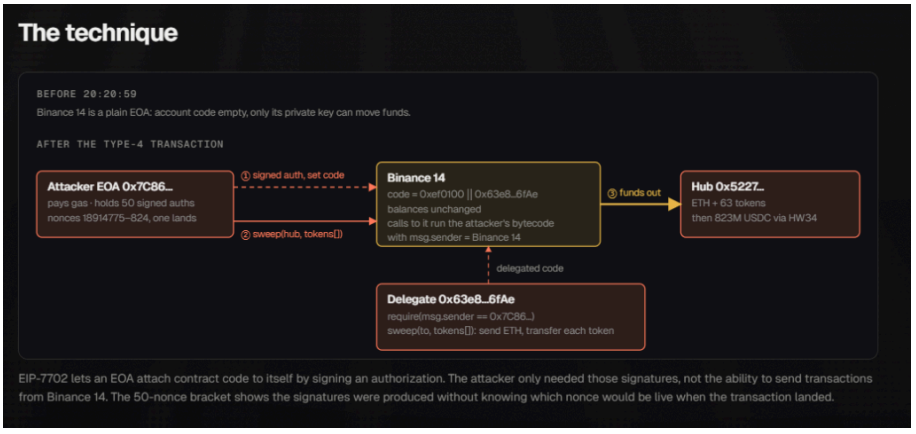


10月28日，攻击者分三次从混币协议Tornado Cash中提取小额资金，用于支付后续部署合约与演练的手续费。

10月29日下午，攻击者部署了最终版恶意合约（地址0x63e842B054Bd624a465454D533C33F573e9c6fAe），该合约编译于Solidity 0.8.28，且只认一个主人：攻击者自己的钱包地址。

10月29日晚间至30日凌晨，攻击者用两个测试钱包把整套攻击流程完整演练了两遍。最后一次测试收工时，距离凌晨4点20分正式动手只剩约3.5小时。

链上分析平台808bits的拆解显示，演练中攻击者分别对测试钱包发起了EIP-7702授权测试，验证了扫空代币的完整流程后，才向真实目标发起攻击。



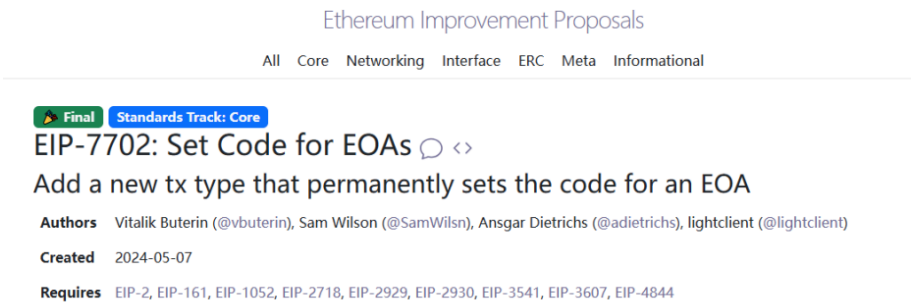
EIP-7702：一扇被“合法”打开的门

真正完成"致命一击"的武器，是以太坊在Pectra升级中引入的新特性：EIP-7702。

要理解它为什么危险，先要理解它本来是做什么的。

在传统以太坊架构里，用私钥控制的普通外部账户（EOA）和智能合约账户是两套完全独立的体系。EIP-7702打破了这道界限——它允许普通钱包通过签发一张特殊授权，把自己账户的代码执行权临时委托给一段智能合约代码。

以太坊官方EIP-7702文件明确警告：**"授权代码可能拥有对账户的广泛访问权限，钱包必须严格审查授权。"**

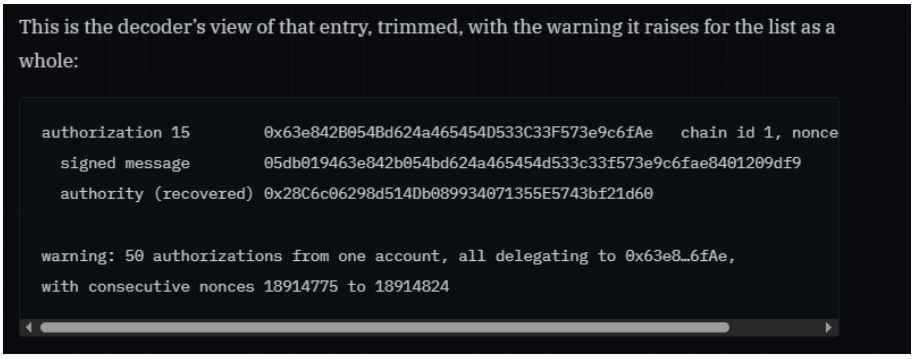


EIP-7702的设计初衷是为了优化用户体验——比如让一个普通钱包能批量处理多笔操作、支持代付Gas等。但它的另一面是：只要那张授权签下去，被委托的程序就能代表钱包主人执行任意操作，包括把所有资产转走。

神鱼在复盘中拆解了这段攻击合约的逻辑："攻击者的程序只认一个主人，只做一件事：转钱。"

凌晨4点20分59秒那笔交易，就是让"Binance 14"热钱包签下了这张授权——50条连续序号的EIP-7702委托，覆盖了18914775至18914824共50个Nonce值。攻击者知道币安热钱包每分钟处理大量交易，无法提前锁定哪个Nonce有效，所以一次性签了50个作为窗口，等一个命中即可生效。





一旦生效，黑客甚至不需要每次都用币安的私钥，直接调用合约就能把64种代币扫空。

真正的问题在哪里？不是合约，是签名

为什么全球安防等级最高的交易所热钱包，会用自己的私钥签下50张连续序号的恶意EIP-7702授权？

神鱼的链上技术诊断是："从链上看，问题出在签名一环，没看到合约漏洞。"

币安的初步调查公告措辞谨慎，但指向了一个具体的切入点：**"安全事件可能涉及一名DevOps工程师的笔记本电脑遭到入侵，攻击者借此获得了某个服务容器的访问权限，并提交了未经授权的提现交易。"**

公告同时表示"目前没有任何钱包私钥泄露的证据"。

808bits分析认为，50个Nonce窗口本身就说明问题所在：如果攻击者直接持有私钥，完全可以自己发起转账，不需要这个窗口机制。 这50个连续签名，更像是攻击者将50个摘要（digest）提交给了某个签名服务，服务按正常流程签名返回，而没有识别出这是一批危险的EIP-7702授权请求。

分析写道："一个在拿到32字节摘要后进行签名的系统，无法区分这个摘要来自一笔正常交易还是一条EIP-7702授权——因为签名对象只有32个字节，上面没有收款方、没有金额、没有调用数据，有的只是'链ID、目标合约地址、Nonce'三个字段。"

这意味着，黑客大概率并非直接窃取了明文私钥文件，而是在币安内部的自动签名系统、权限校验或运维指令管道中撕开了一个口子，诱导签名机签下了那批不该签的Type-4交易。

目前，此次攻击的完整技术路径仍有待币安官方的详细事后调查报告（post-mortem）确认。

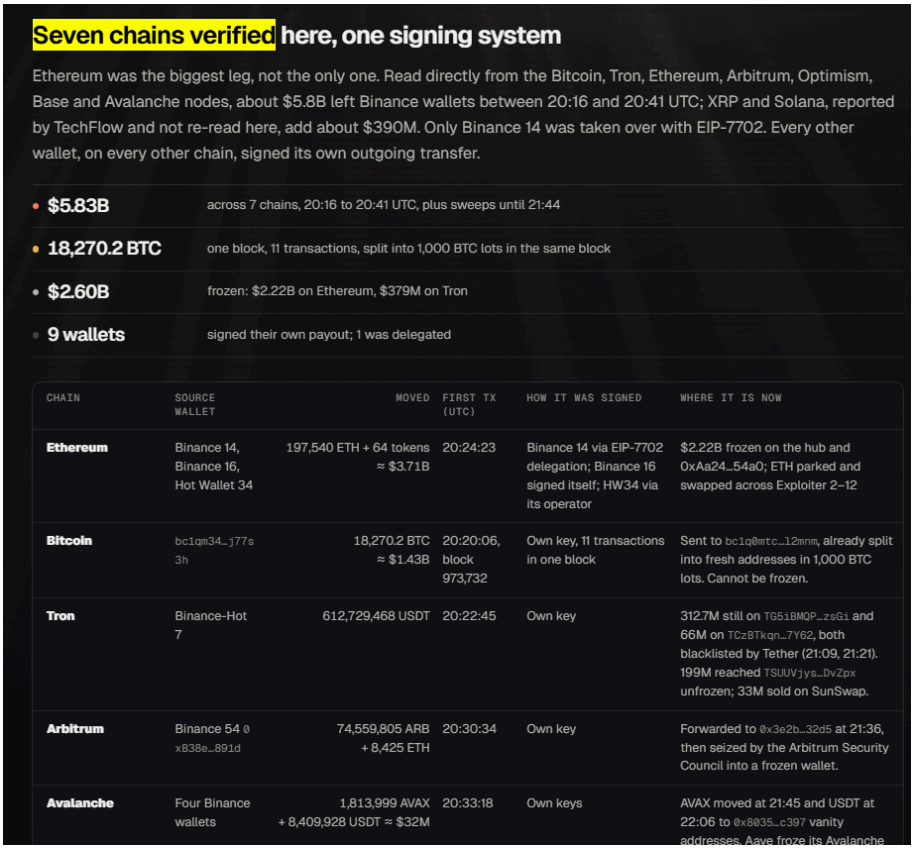
Binance 16的谜题

整个事件中，还有一个细节颇为蹊跷。

链上记录显示，在"Binance 14"被清空约24秒后，币安另一个热钱包"Binance 16"自行签名，向攻击者的集结地址转出了28,005.6枚ETH及约1.08亿美元的其他代币。

"Binance 16"没有EIP-7702委托，它的转账是用自己的私钥直接签名发出的。

分析指出："无论是同一套签名访问权限覆盖了这个钱包，还是一笔内部提现被推送到了攻击者的地址，两种情形都意味着此次入侵的根源在于币安的签名或提现基础设施，而不是某一把被孤立泄露的私钥。"



63亿美元从哪里来：各方口径不一

事发初期，估算相差很大。美媒Axios称，分析师和交易员估计被盗金额在17亿至57亿美元之间。区块链安全机构SEAL 911的Taylor Monahan对《华尔街日报》说，攻击者获利“远超20亿美元”，最高可能达55亿美元。“信息变化很快，确认确切数字还需要时间。”

此后又有几个数字出现：

- 神鱼估算，多链转移总额约58亿美元，并强调这“不是确认的最终被盗损失”。
- 据彭博，Arkham称，疑似黑客关联钱包持有约59亿美元，但不一定等于从币安被盗的金额。
- 币安给出的口径是：预计总影响金额约63亿美元。

币安没有公布最终净损失。

被冻结的30亿：稳定币的另一面

这次事件有一个值得深思的反差：数十亿美元在几分钟内被转走，但其中相当大一部分，又在数小时内被冻结。

事件发生后，多家稳定币发行商迅速行动：

- **Tether：冻结超15.67亿枚USDT，CEO Paolo Ardoino在X平台表示"保护行业和合作伙伴是我们的首要任务"**
- **Circle：冻结逾8亿美元USDC，CEO Jeremy Allaire称"已与执法机构协调，冻结与事件相关的超过8亿美元USDC，并将继续支持调查"**
- **Ripple：冻结约2亿美元RLUSD**
- **World Liberty Financial：冻结约2700万美元USD1**
- **Paxos：冻结约1906枚PAXG**
- **Arbitrum安全委员会：执行紧急交易，将黑客钱包中约3050万美元的ARB和ETH转入冻结钱包**

CZ对Tether的冻结行动评价道："救命恩人。"

CZ 🔶BNB @cz_binance · 6小时

谢谢你！🙏🙏🙏

> 杰里米·阿莱尔 @jerallaire · 7小时
> Circle 正在密切关注有关币安潜在漏洞的报告。我们已与执法部门合作，冻结了与该事件相关的超过 8 亿枚 USDC，并将继续支持调查。

457 315 5,194 55万

CZ 🔶BNB @cz_binance · 6小时

🙏🙏🙏救命恩人

> 保罗·阿尔多伊诺 @paoloardoino · 7小时
> Tether冻结了超过15.67亿USDT，以应对可能发生的币安交易所黑客攻击。保护行业和合作伙伴的安全是我们的首要任务。请大家注意安全。

783 806 1万 104万

CZ 🔶BNB @cz_binance · 7小时

用户资金安全无虞！币安似乎遭到了黑客攻击。感谢 Tether（约 9.71 亿美元）和 Circle（约 8.23 亿美元）迅速冻结资金。我已不再管理币安，但作为股东，我期望所有用户资金都能得到充分保障。

> 树木新闻 @TreeNewsFeed · 7小时
> [🌲] Tether冻结了价值9.71亿美元的USDT，疑似币安黑客攻击，币安方面仍未发布任何更新信息。

4,056 7,452 2.9万 414万

CZ 🔶BNB @cz_binance · 3小时

谢谢你！🙏

> ZachXBT @zachxbt · 4小时
> 突发：仲裁安全委员会已执行一笔交易，冻结了币安漏洞造成的约 3050 万美元损失。感谢所有其他参与签名者。漏洞利用者地址：0x3E2bf1ac6bf0934BBba6456C341c2EcbCED632d5 制裁哈希：

477 220 3,714 39万

CZ 🔶BNB @cz_binance · 5小时

🙏

> 杰克·麦克唐纳 @_JackMcDonald_ · 6小时
> Ripple正密切关注有关币安及其攻击者持有的RLUSD可能遭受攻击的报告，并已积极冻结受影响的资金。我们正在与相关各方协调，随时准备支持任何调查和采取适当行动，以保障用户安全。

319 225 3,014 41万

CZ 🔶BNB @cz_binance · 6小时

谢谢你！🙏🙏🙏

> 扎克·维特科夫 @ZachWitkoff · 6小时
> USD1已采取积极措施，冻结了与币安黑客事件相关的2700万美元USD1账户资金。我们与行业伙伴站在一起。保护用户并防止不法分子转移被盗资金是我们共同的责任。
>
> > 观察者·古鲁 @WatcherGuru · 6小时
> > 突发：全球最大的加密货币交易所币安遭黑客攻击，超过56

据路透社报道，Tether和Circle合计冻结超过23.8亿美元。

然而，被冻结只是第一步。TRM Labs全球政策主管、前美国联邦检察官Ari Redbord解释说："冻结阻止了资金转移，但追回需要通过法律程序。执法机构通常需要获得法院命令或扣押令，才能与稳定币发行商合作，将冻结资产释放并归还受害者。冻结只需要几分钟，但归还资金需要更长时间，不过这条路是存在的。"

Chainalysis研究主管Eric Jardine也表示："没有固定的追回时间表。技术冻结可以很快发生，但归还资金可能需要数月甚至数年。"

比特币、以太坊等没有中心化发行方的资产则是另一回事。 Redbord指出，这类资产无法被直接冻结，调查人员只能追踪资金在交易所、跨链桥和其他服务中的流向，等待其出现在能够配合执法的平台上。

据DRK链上分析，被转走的约18,270枚BTC（约14.3亿美元）目前仍完好无损，黑客尚未移动。而约37.7万枚ETH分散停放在多个钱包地址。

从Bybit到币安：攻击者在进化

这不是加密行业第一次遭遇此类攻击，但规模的变化令人警惕。

2025年2月，Bybit冷钱包遭遇黑客攻击，损失约15亿美元。网络安全研究公司TRM Labs和Pangolin Intelligence事后将该攻击归因于亚洲某国关联黑客组织TraderXXXitor。彼次攻击的核心手法，是通过入侵Safe钱包的开发环境，诱骗多签审批者批准一笔经过伪装的恶意交易。

这一次，Blockaid联合创始人兼CEO Ido Ben-Natan公开表示，此次攻击与Bybit事件"非常相似"。

不过，目前Elliptic、Chainalysis等多家机构尚未发出正式归因声明，调查仍在进行中。

两次攻击有一个共同特征，Bybit的多位签名者看到的是一笔正常转账，实际上签掉的是一个代理合约升级；这一次，币安的签名系统看到的可能是一批普通的32字节摘要，实际上签掉的是50张EIP-7702授权委托书。808bits对此总结道："攻击者没有正面攻破保险柜，而是让签名系统自己打开了门。"

据华尔街日报，TRM Labs全球政策主管Ari Redbord将本次事件称为**"人类历史上最大的银行劫案"**。

攻防之间，没有永久的平衡

这次事件发生后，行业层面的讨论随即展开。

Immunefi CEO Mitchell Amador此前多次公开警告，AI工具正在降低高水平攻击的门槛，防御方需要时间追平差距。加密行业安全公司Cyvers CEO Deddy Lavid称，加密行业是"第一个真正感受到AI冲击的市场"。

TRM Labs的Redbord则提供了另一面的视角："攻击者以空前的速度和规模运作，但追踪和溯源的工具也在同等速度下运行。稳定币发行商在数小时内完成冻结，调查人员实时追踪跨链资金。"

这场追与逃，在本次事件中得到了具体呈现：攻击者在9分钟内将约3.35亿枚USDT通过Uniswap换成了ETH，赶在Tether冻结指令生效之前完成了变现；而剩余的大量USDT和USDC，则在被转入集结钱包后不久即遭冻结，无法移动。

目前，约30亿美元已被冻结；约33亿美元的BTC、ETH及其他无法被中心化冻结的资产，仍处于链上追踪状态。

风险提示及免责条款

市场有风险，投资需谨慎。本文不构成个人投资建议，也未考虑到个别用户特殊的投资目标、财务状况或需要。用户应考虑本文中的任何意见、观点或结论是否符合其特定状况。据此投资，责任自负。

限时权益申领 * 体验资格每人限申领一次
VIP会员·7天畅读卡 | 大师课·入门串讲
扫码 免费领取

限免

393 收藏 分享到:

写评论

请发表您的评论

表情 图片 发布评论

4 条评论

手机用户
52分钟前 中国山东省

美国洗劫财富开始了，随时关闭服务器

0 回复

MobileUser7668 VIP会员
1小时前 中国江苏省

自导自演的，这个位置包跌的。马上全部拉回去。信不信等着瞧。

0 回复

MobileUser0819
2小时前 中国河北省

AI发展太快，监管能力不足，网安该加大研究了

1 回复

wscn1553175943
2小时前 日本

十月份拉一坨大的是币安周年庆活动了？

2 回复